

exposed to the Internet, but is separated from it by an additional firewall. This design method is well-known, and is called a demilitarised zone (DMZ). In earlier days, it was a practice to keep database servers in the same network as the front-end/Web application servers, making them prone to attacks. An additional layer of security is now achieved by the second firewall, which opens up only the database port for the front-end servers, and not the IP addresses of the entire Internet. If the database carries mission-critical data-sets of sensitive information, this method can be clubbed together with the NAT-PAT method, making it even harder for malware to breach the database server.

Content-based firewalls

The latest firewall products are equipped with the capability to look into the data packets flowing in either direction, and provide systems administrators a means to configure actions based on the intercepted content. These firewalls, sometimes called Layer-7 firewalls, are capable of reading SQL queries, query data, validation data, XML data, etc. Deploying such a firewall can certainly reduce virus attacks drastically, because data packets pertaining to ill-behaved operations are dropped and reported.

SSL connections

While SSL technology is commonly used to secure Web-server connections to browsers, it can also be used between front-end servers and the back-end database server. SSL uses public-key and private-key cryptography to encrypt all connections between caller and listener. While this solution is a bit costly and takes a toll on data-transfer speeds, it is worth the effort to alleviate man-in-the-middle attacks.

IPSec security

The real challenge while securing a database server is to figure out who should access it. In terms of people, it is as simple as deploying user-ID and password-based access. However, if the network is compromised by a hacker, this won't help much. A further step, in such a case, would be to deploy IPSec security, whereby each server will connect to the database server using an IPSec token, making it a unique and non-crackable connection.

Securing open source databases

A database administrator always carries out the essential chores to secure a database; however, for Linux-based open source solutions, a little extra effort is required. While there is no single solution to cover all open source database distributions, there are a few good tools for each.

A popular open source database is MySQL, which is used by many commercial websites as their back-end.

MySQL comes with the necessary scripts to harden the server from the security perspective, such as scripts to remove test databases, lower system and database privileges, enable the built-in Linux firewall to configure default database ports and block others, etc.

MongoDB and CouchDB are two famous database servers running on Apache distributions. Both come equipped with the great feature of IP binding, whereby the database kernel services are bound to one single IP. Adding an open source content firewall or a NAT-PAT solution can help create a very cost-effective and, yet, secure database farm.

The Hypertable open source database, which is modelled after Google's BigTable DB structure, provides an extensive library of API calls that are used exclusively for adding security features. It is easy to write scripts using those API calls, to securely deploy and configure Hypertable distributions in a big server farm.

Unlike Microsoft SQL Server, Oracle and Sybase products, while designing security for open source products, it is important to incorporate a combination of network security methods, as well as the database product's application-layer security.

Summary

While much effort goes into securing a database, due diligence is required to secure the server hosting the database too. The security measures taken for the application layer as well as the network layer must go hand-in-hand to keep mission-critical data safe from hackers. A rock-solid change-control process needs to be in place to tighten the IP stack, the patch-management solutions, as well as the physical security. It is often found that Layer-2 security is not designed adequately, or in some cases is simply absent, which makes all the application-layer security measures futile. Senior IT management and database administrators need to work with systems administrators to amicably formulate an end-to-end security solution. This applies to all database-centric solutions, irrespective of whether they are off-the-shelf or FOSS-based. 

By: Prashant Phatak

The author has over 18 years of experience in the field of IT hardware, networking, Web technologies and IT security. For the past 11 years, he worked in the USA as a VP (Global head of Technology Operations) at the Wall Street firm, Merrill Lynch (New York). In the IT security world, he is an ethical hacker, and a member of the ISACA USA chapter. Currently, Prashant runs his own firm named Valency Networks (www.valencynetworks.com) in India, providing consultancy in IT security, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com